

권 고

12

제 목 IT 시스템 권한 관리 미흡

관 계 기 관 ○○○○○○○(주)

구 분 총무

내 용

1. 업무개요

○○○○○○○○(주)는 원활한 업무 수행을 위해 그룹웨어, ERP와 같은 IT 시스템을 활용하고 있으며, 본사 임직원 및 지점의 지점장, 팀장, 행정업무 담당 직원 등에게 직무에 따라 각 시스템별 계정을 부여하여 [표 1]과 같이 운영하고 있다.

[표 1] IT 시스템 계정 운영 현황

시스템	사용 중인 계정 수	보유 계정 수(한도)	권한부여 담당부서
더존 그룹웨어	375개	380개	◇◇◇◇팀
더존 ERP ¹⁾	19개	19개	◆◆◆◆팀, ▲▲팀
ECOUNT ERP ¹⁾	63개	- ²⁾	▲▲팀

주1. 더존 ERP는 예산 ▲▲회계분야 업무 시 사용하고 있고, ECOUNT는 최초 그룹웨어와 ERP시스템이었으나, 더존 그룹웨어·ERP 도입 이후 현재는 급여업무 ERP 기능만을 사용하고 있음

2. 계정 생성 한도 없음

자료: ○○○○○○○(주) 제출자료 재구성

2. 관련법령 및 판단기준

감사원은 공공부문에서 기관의 효과적인 내부통제시스템 설계·운영을 지원하기 위해 「공공부문 내부통제 가이드라인」³³⁾(이하 “가이드라인”이라 한다)을

배포하였고, ○○○○○○○(주)는 공직유관단체³⁴⁾로서 이를 참고하여 기관의 목표 달성에 도움이 되도록 기관 내 효과적인 내부통제시스템을 구축하고 운영하여야 한다.

가이드라인 원칙 11³⁵⁾에 따르면 최고관리자(사장)는 직원의 입·퇴사 또는 전보 발생 시 권한을 신속하게 수정·회수하고, 직급 및 담당업무, 정보자원 중요도 등을 고려하여 IT 시스템을 사용하는 직원에게 적절한 접근권한(실제 업무분장과 IT 시스템 권한이 일치)을 부여하여 시스템 내 데이터의 부적정한 수정이나 삭제 위험으로부터 정보를 보호하여야 한다.

따라서 신입 직원의 입사, 기존 직원의 퇴사 또는 인사발령으로 인한 이동이 발생하는 경우에는 ▲▲부서에서 해당사항을 IT시스템 담당부서(담당자)에 통보하여 관련자에 대한 시스템 사용 권한을 신속하게 조정할 수 있도록 하여야 하고, 시스템 내 권한 조정 및 데이터를 수정·삭제할 수 있는 ‘마스터’ 권한은 IT 시스템별 업무 담당자에게만 부여하는 등 권한 부여를 최소화하여 시스템 내 데이터의 무결성³⁶⁾을 보장하도록 하여야 한다.

3. 감사결과 확인된 문제점

가. ▲▲정보 변경 통보절차 미흡

그런데 ○○○○○○○(주)는 직원의 ▲▲ 변동이 발생하더라도 ▲▲부서에서 IT 시스템 담당부서로 별도의 통보하는 절차가 마련되어 있지 않아 시스템 담당

33) 공공부문 내부통제업무 지원을 위한 안내자료로서 2023. 10. 24.에 배포

34) ○○○○○○○(주)는 2018. 7. 공직유관단체로 지정되었음

35) 「공공부문 내부통제 가이드라인」 원칙 11. IT 시스템에 대한 통제활동을 개발한다.

36) 데이터의 정확성 및 완전성, 일관성을 유지하는 것을 의미하며 데이터가 의도적 또는 우발적 손상으로부터 보호되도록 보장하는 개념

자가 그룹웨어 내 문서함의 전자문서를 확인하여 권한을 조정하고 있어 담당자가 이를 놓치거나 부재 중일 경우 권한 변경이 지연 또는 누락되어 정보유출 및 통제 실패 등이 발생할 위험이 있다.

나. ‘마스터’ 권한 부여 등 권한 관리 미흡

또한 그룹웨어 시스템 내 데이터(문서, 게시판 등)를 임의로 신설·수정·삭제할 수 있는 ‘마스터’ 권한을 [표 2]의 ‘연번 1, 2’와 같이 그룹웨어 관리 업무 담당자가 아닌 직원에게 필요 이상으로 확대하여 부여하고 있다.

[표 2] 그룹웨어 마스터 권한 부여현황

연번	소속	성명	권한	관련 업무분장
1	▼▼▼▼▼	김○○	마스터	▼▼▼▼▼ 업무 총괄
2	▽▽▽▽▽	이○○	마스터	▽▽▽▽▽ 업무 총괄
3	◇◇◇◇팀	오○○	마스터	◇◇◇◇팀 업무 총괄 및 그룹웨어 관리
4	◇◇◇◇팀	김○○	마스터	그룹웨어 관리(부)
5	↑↑지점	관리자	마스터	관리자(admin)

자료: ○○○○○○○○(주) 제출자료 재구성

한편 그룹웨어 시스템의 권한은 총 27개³⁷⁾로 세분화되어 있는데, 그 중 ‘Test’, ‘자원승인담당자³⁸⁾’, ‘권한관리자³⁹⁾’와 같은 일부 권한은 사용목적이 불명확하거나 실제로 사용하지 않는 과거에 부여한 권한으로 장기간 정비하지 않은채 유지하고 있었다.

37) 감사업무, 권한관리자, 근무조 수기등록, 기록물 업무, 문서열람 권한, ▲▲관리, 문서 삭제 권한, 자원승인, 재직 증명서 발급, 회계관리, Test 등 27개 권한

38) 자원승인담당자 권한은 일반 사용자 대비 별도로 추가 설정된 권한이 없으나, 현재 □□□□팀장에게 부여되어 있음

39) 권한관리자 권한은 그룹웨어 내 권한을 신설·삭제·조정하거나 임직원에게 권한을 부여할 수 있는데, 현재 ◆◆◆◆◆장, ▲▲팀 직원 1인에게 부여되어 있음

ECOUNT 시스템의 경우에도 총 전체 계정 중 상당수가 사용하지 않는 계정⁴⁰⁾임에도 정리하지 않았고, 일부 계정에는 과거 업무분장 상의 세무 관련 권한이 그대로 부여되어 있는 등 직원의 현행 업무와 일치하지 않는 권한 부여 상태가 지속되고 있어 데이터 무결성 훼손에 관한 리스크가 상존하고 있다.

관계기관 의견 및 검토결과 ○○○○○○○(주)는 ‘나항’에 관하여 「그룹웨어 보안 문서 운영 및 외부 문서 수발신 체계 정비(안)」을 2025. 6. 20.에 수립하여 기존 본사 각 팀장에게 부여하던 마스터 권한을 현재의 마스터 권한으로 조정하였으며, 조직 규모·인력 구조 상 IT 전담부서가 존재하지 않는 상황에서 마스터 권한 체계를 [표 2] ‘연번 1, 2’에 해당하는 ▼▼▼▼장⁴¹⁾, ▽▽▽▽장⁴²⁾ 2인 중심으로 전환하고 ◇◇◇◇팀 직원에게 보조 마스터 권한을 부여하여 이중 승인 체계로 운영한 것으로 그룹웨어 마스터 권한을 무분별하게 확대한 것이 아닌 책임과 통제의 축을 명확히 하기 위한 방향으로 권한 구조를 재설계한 것이라고 의견을 제시하였다.

그러나 적극적으로 기존의 각 팀장에게 과다하게 부여한 마스터 권한을 별도의 기준을 수립하여 조정한 부분의 노력은 인정하나, 가이드라인에서 권고하는 ‘마스터’ 권한 부여 최소화의 취지는 시스템 내 데이터의 무결성을 보장하기 위한 것으로, 그룹웨어 관리 보조 담당자의 경우, 담당자의 부재 등을 대비하여 부여할 수 있다고 보여지나, ▼▼▼▼장, ▽▽▽▽장은 실제 전사의 업무를 총괄하여

40) 63개 계정 중 실질적으로 사용하는 계정은 13개 정도며, 그 중 1개 계정에는 과거 업무분장 상의 권한이 그대로 부여되어 있었음

41) 전략, 조직·▲▲, 예산 조정 등 기획기능 총괄 담당자

42) 사무·기록물 관리 및 문서수발 등 행정·운영 관리 총괄 담당자

담당하고 있지만 총괄담당자로서 시스템 내 권한 조정 및 데이터를 수정·삭제 업무를 직접 수행하지 않고 실무처리는 ◇◇◇◇팀장이 하고 있으므로 관련자들에게 별도의 마스터 권한을 부여하는 것은 데이터의 우발적 손상에 대한 위험 등이 존재하므로 위 의견을 받아들이기 어렵다.

한편 ‘가항’과 관련하여서는 감사결과에 이견을 제시하지 않았다.

조치할 사항 ○○○○○○○○(주) 대표이사는 인사 변동 시 IT 시스템 권한 조정이 적절하게 반영될 수 있도록 ▲▲부서와 시스템 관리부서 간 통보체계 마련하고, IT 시스템별 불필요한 권한 삭제 및 마스터 권한을 담당자 중심으로 최소화하여 재설정하는 등 관련 업무를 철저히 하시기 바랍니다. (권고)